

1) Cenário: Instituição e Sistema de Suporte

i) Como poderia utilizar os recursos disponibilizados para implementar tolerância a falha dos serviços (base de dados, etc.)? (3,0 valores)

Para maximizar a disponibilidade com o hardware fornecido (2 Web, 2 DB, 1 Storage), a arquitetura sugerida seria:

- **Servidores Web (2 unidades):**
 - Configurar num **Cluster de Balanceamento de Carga (Load Balancing)**.
 - *Mecanismo:* Um balanceador (software como HAProxy ou Nginx, ou via DNS Round-Robin/VIP) distribui os pedidos. Se um servidor falhar, o outro assume todo o tráfego.
 - Como os dados estão no servidor de ficheiros, os servidores web não precisam de replicar conteúdo entre si, apenas montar o armazenamento partilhado.
- **Servidores de Base de Dados (2 unidades):**
 - Configurar num **Cluster de Alta Disponibilidade (Failover)**.
 - *Mecanismo:* Configuração Ativo-Passivo ou Ativo-Ativo (Master-Slave ou Master-Master Replication no MySQL).
 - *Ponto Crítico:* O enunciado diz que o servidor de ficheiros aloja a BD. Isso implica que o motor

MySQL corre nos servidores de DB, mas os ficheiros de dados (`datadir`) estão montados via rede (NFS/iSCSI) a partir do servidor de ficheiros. Para tolerância a falhas, se o nó MySQL principal cair, o secundário assume o apontador para os ficheiros.

- **Servidor de Ficheiros (1 unidade com RAID1):**
 - O RAID1 protege contra falha de *disco*, mas não contra falha do *servidor*.
 - *Nota:* Este servidor é um **SPOF (Single Point of Failure)**. Se a motherboard/fonte deste servidor queimar, todo o sistema para. A resposta deve mencionar que o RAID1 garante a integridade dos dados em caso de falha de um disco, e este servidor servirá os dados via rede (NFS/SMB) para os outros 4 servidores.
-

ii) Tabela de Ameaças e Vulnerabilidades (Helena Mars) (4,0 valores)

Cenário: Helena acumula funções (Financeiro + TI), leva portátil para casa, faz backups em disco externo pessoal.

1-ii) Tabela de Ameaças e Vulnerabilidades (Formato Lista)

Situação 1: Helena leva o portátil para casa

- **Vulnerabilidade:** Transporte físico de equipamento crítico fora do perímetro de segurança da empresa.
 - **Ameaça:** Roubo, Furto ou Perda do equipamento.
 - **Afeta (CIA):** [X] Confidencialidade, [] Integridade, [X] Disponibilidade.
 - **Impacto: Alto** (Perda do ativo físico e exposição de dados confidenciais).
-

Situação 2: Backup em disco externo pessoal em casa

- **Vulnerabilidade:** Falta de cifragem (criptografia) em dispositivo de armazenamento não gerido pela empresa.
 - **Ameaça:** Acesso não autorizado aos dados (por terceiros em casa ou em caso de perda do disco).
 - **Afeta (CIA):** [X] Confidencialidade, [] Integridade, [] Disponibilidade.
 - **Impacto: Alto** (Fuga de informação financeira sensível - Data Breach).
-

Situação 3: Acumulação de funções (Financeira + TI)

- **Vulnerabilidade:** Inexistência de Segregação de Funções (o utilizador tem privilégios excessivos e conflituosos).
- **Ameaça:** Fraude interna intencional ou erro humano não detetado (ninguém fiscaliza quem tem poder total).

- **Afeta (CIA):** [X] Confidencialidade, [X] Integridade, [X] Disponibilidade.
 - **Impacto: Muito Alto** (Pode manipular dados financeiros e apagar os registos/logs de auditoria para esconder o rasto).
-

Situação 4: Trabalho através de rede doméstica

- **Vulnerabilidade:** Utilização de rede Wi-Fi doméstica com segurança fraca (WEP/WPA antigo) ou partilhada com outros dispositivos inseguros (IoT).
 - **Ameaça:** Interceção de tráfego (*Sniffing*) ou movimento lateral de *Malware* de outros dispositivos infetados na casa.
 - **Afeta (CIA):** [X] Confidencialidade, [X] Integridade, [] Disponibilidade.
 - **Impacto: Médio/Alto** (Comprometimento de credenciais de acesso à VPN ou sistemas da empresa).
-

iv) Efetue a avaliação quantitativa de risco. (3,0 valores)

Pressupostos (Valores Hipotéticos):

Para este exercício, vamos atribuir os seguintes valores estimados aos ativos e probabilidades mencionadas no cenário da Helena Mars:

- **Valor do Portátil + Dados Confidenciais:** 5.000€

- **Custo de recuperação de uma infecção por Malware (Serviço técnico + Paragem): 1.000€**

Tabela 1: Cálculo da Expectativa de Perda Única (SLE)

Esta tabela define quanto perdemos se o incidente acontecer uma única vez.

Fórmula:

$SLE = \text{Valor do Ativo (AV)} \times \text{Fator de Exposição (EF)}$

Ativo / Risco	Valor do Ativo (AV)	Fator de Exposição (EF)	SLE (Perda Única)	Justificação
Roubo do Portátil	5.000 €	100% (1.0)	5.000 €	Se roubado, perde-se o equipamento e a totalidade dos dados locais.
Infeção por Malware	1.000 €	50% (0.5)	500 €	O portátil não é destruído, mas requer formatação e horas de trabalho técnico (perda parcial).

Tabela 2: Cálculo da Expectativa de Perda Anual (ALE)

Esta tabela define o custo anual do risco, cruzando a perda única com a frequência do evento.

Fórmula: $ALE = SLE \times \text{Taxa Anual de Ocorrência (ARO)}$

Ameaça / Risco	SLE (da Tabela 1)	Taxa Anual de Ocorrência (ARO)	ALE (Risco Anual)	Análise
Roubo do Portátil	5.000 €	0.2 (uma vez a cada 5 anos)	1.000 €	O risco financeiro anual é elevado.
Infeção por Malware	500 €	2.0 (duas vezes por ano)	1.000 €	Apesar de cada incidente ser "barato", a frequência alta torna o custo anual igual ao do roubo.

Resumo da Avaliação:

Com base nestas tabelas, o risco anualizado para ambas as situações é de 1.000€/ano. Isto significa que a empresa

deveria gastar, no máximo, 1.000€ por ano em controlos (antivírus, seguros, encriptação) para mitigar cada um destes riscos. Se o controlo custar mais que o ALE, não compensa financeiramente.

v) Plano de tratamento de risco para pelo menos 3 riscos identificados. (2,0 valores)

O tratamento pode ser: Mitigar, Transferir, Aceitar ou Evitar.

1. Risco: Roubo do Portátil (Confidencialidade)

- *Tratamento (Mitigar):* Implementar **Cifragem de Disco Total (Full Disk Encryption)** (ex: BitLocker) no portátil. Assim, mesmo se roubado, os dados não são lidos.

2. Risco: Backup em disco externo inseguro

- *Tratamento (Evitar/Mitigar):* Proibir backups em dispositivos pessoais não geridos (Política de Segurança). Fornecer uma solução de **Backup na Cloud corporativa** ou via VPN direta para o servidor da empresa.

3. Risco: Acumulação de Funções (Financeiro + TI)

- *Tratamento (Mitigar/Transferir):* Contratar um serviço externo (Outsourcing) para a gestão de TI ou contratar um técnico dedicado, garantindo a **Segregação de Funções**. Retirar permissões de administração de sistemas à Helena.
-

Questões Teóricas

2) Diferenças entre Cluster de Alta Performance (HPC) e Cluster de Balanceamento de Carga. (2,0 valores)

- **Cluster de Alta Performance (HPC):**
 - *Objetivo:* Capacidade de processamento.
 - *Funcionamento:* Divide uma tarefa complexa em pequenas partes que são processadas em paralelo por vários nós ao mesmo tempo.
 - *Exemplo:* Previsão meteorológica, renderização de vídeo 3D, cálculos científicos.
- **Cluster de Balanceamento de Carga (Load Balancing):**
 - *Objetivo:* Disponibilidade e escalabilidade (atender mais utilizadores).
 - *Funcionamento:* Distribui *muitos* pedidos pequenos entre vários servidores. Cada nó processa um pedido inteiro independente.
 - *Exemplo:* Servidores Web (Google, Facebook) atendendo milhares de utilizadores simultâneos.

3) Importância de um plano de continuidade de negócio (BCP). (2,0 valores)

O BCP (Business Continuity Plan) define como a organização continua a operar (mesmo que em modo degradado) durante e após um desastre.

- **Importância:**

- Garante a **sobrevivência** da empresa.
- Minimiza prejuízos financeiros decorrentes da paragem.
- Protege a reputação e imagem da marca.
- Garante o cumprimento de obrigações legais (Compliance) e contratuais (SLA).

4) Relação com fornecedores e impacto negativo num sistema crítico. Controlos associados. (2,0 valores)

- **Impacto Negativo:** Um fornecedor pode ser o elo mais fraco. Se ele falhar (falência, ataque informático), a organização pode sofrer interrupção de serviço (Supply Chain Attack) ou fuga de dados que o fornecedor geria.
- **Controlos:**
 - **SLA (Service Level Agreement):** Definir níveis de serviço e penalizações por falha.
 - **Cláusulas de Auditoria:** Direito de a empresa auditar a segurança do fornecedor.
 - **NDA (Non-Disclosure Agreement):** Acordos de confidencialidade.
 - **Redundância:** Ter fornecedores alternativos homologados para o mesmo serviço.

5) Comente: "Numa análise de Risco a avaliação quantitativa pode influenciar diretamente o plano de tratamento de risco." (2,0 valores)

Afirmação Verdadeira.

A avaliação quantitativa atribui um valor financeiro ao risco (ALE - Perda Anual Esperada). Isso permite uma análise de Custo-Benefício (ROI de Segurança).

- *Explicação:* Só faz sentido implementar um controlo (tratamento) se o **custo do controlo for inferior ao valor do risco (ALE)**.
 - *Exemplo:* Se o risco de perder dados custa 1.000€/ano, mas o software de proteção custa 5.000€/ano, a decisão racional (baseada na avaliação quantitativa) seria **Aceitar** o risco, em vez de o **Mitigar**, pois o tratamento é mais caro que o problema.
-